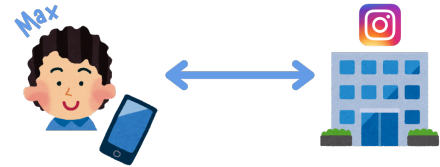


Passwörter

1. Login mit Account und Passwort

Um die Funktionen eines Passworts zu verstehen, betrachten wir folgende Leitfrage an einem konkreten Beispiel:

Woher weiss Instagram, dass sich wirklich Max mit seinem Konto anmelden möchte?



Stellen wir uns vor, Max möchte sich auf seinem Handy bei Instagram anmelden. Er gibt seinen Benutzernamen und sein Passwort ein. Instagram überprüft die Angaben und gewährt ihm anschliessend Zugriff auf sein Konto. Doch was passiert dabei eigentlich?

a) Identifikation

Zuerst muss Max angeben, wer er ist. Zum Beispiel gibt er seinen Benutzernamen oder seine E-Mail-Adresse ein. Das nennt man **Identifikation**. Die Identifikation beantwortet also die Frage: *Wer behauptest du zu sein?*

b) Authentifizierung

Nur zu behaupten, dass man Max ist, reicht natürlich nicht. Sonst könnte sich jeder als Max ausgeben. Instagram muss deshalb überprüfen, ob Max tatsächlich derjenige ist, für den er sich ausgibt. Daher gibt Max also sein Passwort an. Das nennt man **Authentifizierung**. Die Authentifizierung beantwortet also die Frage: *Kannst du beweisen, dass du wirklich Max bist?*

Ein Passwort ist dabei ein sogenannter **Authentifizierungsfaktor**. Es zur Kategorie «Etwas, das (nur) du weisst».

b) Autorisierung

Wenn Instagram erfolgreich überprüft hat, dass Max wirklich Max ist, stellt sich eine weitere Frage: *Was darf Max jetzt machen?*

Max darf beispielsweise seine eigenen Fotos ansehen, Nachrichten lesen oder Beiträge veröffentlichen. Er darf aber nicht einfach die privaten Nachrichten eines anderen Benutzers lesen oder dessen Konto verändern. Das nennt man **Autorisierung**. Die Autorisierung beantwortet also die Frage: *Was darfst du tun?*

Beispiele von Authentifizierungsfaktoren

Ein Passwort ist nur ein möglicher Authentifizierungsfaktor. Es gibt aber noch weitere Möglichkeiten, um die Authentifizierung durchzuführen. Dabei unterscheidet man zwischen 3 Kategorien:

Etwas, das du weisst

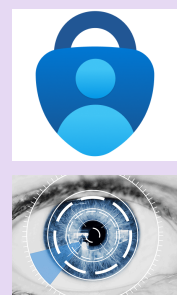
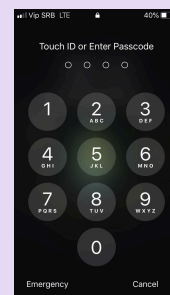
Dazu gehören zum Beispiel Passwörter, PINs, Sicherheitsfragen oder Muster.

Etwas, das du besitzt

Dazu gehören zum Beispiel Schlüssel, Smartphones oder Authenticator-Apps

Etwas, das du bist

Dazu gehören zum Beispiel ein Fingerabdruck, die Iris oder das Gesicht. Diese Kategorie wird auch als Biometrie bezeichnet.



Diese Faktoren können auch kombiniert werden. Wenn Max z.B. neben seinem Passwort noch einen Code aus einer Authenticator-App eingeben muss, verwendet er zwei Faktoren - auch **Multi-Faktor-Authentifizierung (MFA)** genannt. Das erhöht die Sicherheit, da ein Angreifer nun beide Faktoren kennen muss, um sich als Max auszugeben.

Jetzt haben wir geklärt, wie Instagram sich sicher sein kann, dass sich auch wirklich Max anmelden möchte. Nun stellt sich aber schon die nächste Frage: Wenn Instagram mein Passwort kennen muss, muss Instagram es dann auch irgendwo speichern?

2. Wie werden Passwörter gespeichert?

Vorhin haben wir gesehen, dass Max sich bei Instagram mit seinem Benutzernamen und Passwort einloggen muss. Nehmen wir mal an, Max verwendet das Passwort «Sommer2026!». Eine sehr einfache Möglichkeit wäre, dass Instagram dieses Passwort direkt in seiner Datenbank speichert.

Die Datenbank könnte beispielsweise so aussehen wie in Tabelle 1. Das nennt man **Klartextspeicherung**. Wenn Max sich anmeldet, kann Instagram das eingegebene Passwort einfach mit dem gespeicherten Passwort vergleichen. Das funktioniert zwar technisch, ist aber äusserst unsicher... Warum?

Benutzer	Passwort
Max	Sommer2026!
Anna	Fussball123
Luca	Mauzi
Sara	123456789

Tabelle 1: Datenbank mit Klartext

Die Übermittlung selbst kann man zwar mit einer Verschlüsselung irgendwie sichern, sodass keine Eve das Passwort abfangen kann. Aber in dieser Situation gibt es noch eine weitere Schwachstelle. Angenommen, ein Angreifer verschafft sich Zugriff auf die Datenbank bei Instagram. Dann könnte er sofort alle (!) Passwörter lesen! Er müsste die Passwörter also nicht einmal knacken, sondern könnte sie einfach so verwenden. Deshalb sollten Passwörter niemals im Klartext gespeichert werden.

2.1. Die Idee der Hashfunktion

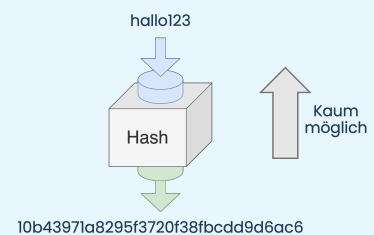
Hier kommt ein Prinzip ins Spiel, das wir schon aus der Kryptologie bei der asymmetrischen Verschlüsselung kennengelernt haben: Die Hashfunktion.

Repetition Hashfunktion

Wir haben schon einmal die Hashfunktion kennengelernt. Sie hat die Eigenschaft, dass sie eine Input nimmt und in eine ganz andere Form bringt. Dabei ist es praktisch unmöglich, aus dem Hashwert wieder das ursprüngliche Passwort zu berechnen (Beispiel Spaghetti kochen).

Ein weiteres Merkmal in der Informatik bei Hashfunktionen ist, dass sie eine beliebige Länge als Input reinnimmt (z.B. ein Passwort) und daraus einen Hashwert mit einer fixen Länge erstellt. Das heisst, egal wie lang das Passwort ist, die gespeicherten Hashwerte haben immer die gleiche Länge.

Der konkrete Hashwert hängt natürlich von der verwendeten Hashfunktion ab. Wichtig dabei ist: Aus demselben Passwort entsteht bei derselben Hashfunktion immer derselbe Hashwert.



Das Ganze sieht einer Verschlüsselung verdächtig ähnlich... Aber hier müssen wir eine Unterscheidung machen:

Bei einer Verschlüsselung wird eine Nachricht so verändert, dass sie ohne den passenden Schlüssel nicht gelesen werden kann.

Beim Hashing wird aus einer Eingabe ein Hashwert berechnet. Und dieser Wert ist nicht dazu gedacht, wieder in die ursprüngliche Eingabe zurückverwandelt zu werden. Deshalb spricht man hier von einer Einwegfunktion.

insert image vergleich verschlüsselung hash

Wie kann Instagram dann das Passwort überprüfen?

Bei der Registrierung von Max speichert Instagram nicht sein Passwort als Klartext, sondern übersetzt dieses mit einer Hashfunktion in einen Hashwert (vereinfacht auch Hash genannt). Die Datenbank sieht also nicht mehr wie in Tabelle 1 aus, sondern wie in Tabelle 2. Das eigentliche Passwort ist nicht mehr ersichtlich.

Benutzer	Passwort
Max	0ec22f12d2aef35308467e125d3996de
Anna	7ed70c52ce29499ba647a775cec40d6d
Luca	2981b5bf5f6772a8b0f2c43b5f98e80a
Sara	25f9e794323b453885f5181f1b624d0b

Tabelle 2: Die Datenbank bei Instagram speichert nicht das Passwort als Klartext, sondern den Hashwert des Passworts.

Einige Tage später möchte Max sich wieder anmelden. Instagram wird nun nicht das Passwort direkt mit dem gespeicherten Passwort vergleichen, sondern es zuerst wieder mit derselben Hashfunktion in einen Hashwert umwandeln. Dann werden die zwei Werte verglichen. Wenn sie übereinstimmen, wird die Anmeldung akzeptiert, andernfalls abgelehnt.

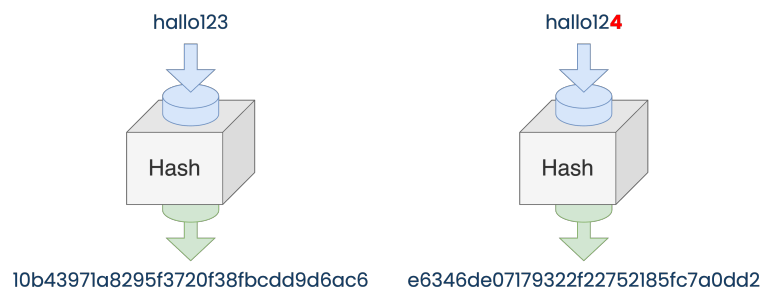
Der Server bei Instagram muss das eigentliche Passwort also nicht kennen, um überprüfen zu können, ob das richtige Passwort eingegeben wurde.

2.2. Besonderheiten bei Hashes

Nun ergeben sich natürlich einige Besonderheiten bezüglich dieses Verfahrens. Gehen wir nun auf diese ein.

Avalanche Effekt

Eine wichtige Grundvoraussetzung ist, dass man nicht aus dem Hashwert das Passwort irgendwie zurückrechnen kann. Daher ist es auch wichtig, dass sich der Hashwert bei einer kleinen Änderung des Passworts stark verändert. Das nennt man den **Avalanche Effekt**.



Im Beispiel im Bild sieht man, dass eine Änderung eines einzelnen Buchstabens im Passwort dazu führt, dass der Hashwert komplett anders aussieht.

3. Angriffe

3.1. Wie kommen ANgreifer an Passwörter?

3.2. Was passiert bei einem Datenleck?

4. Zentrales Login: Unser Email

5. Bad & Good Practices

Lösungen